

AI Marketing Governance Checklist

43-item governance review covering approval workflows, audit architecture, brand control, AI agent authority, and access control. For legal, compliance, and operations teams.

43 ITEMS

LEGAL · COMPLIANCE · OPS

PDF · UNGATED

2026 EDITION

How to use this checklist

Score each item: green tick = Implemented | amber bolt = Partial / In Progress. Items marked (Critical) represent governance failures with immediate legal or brand consequences. Achieve 100% on all Critical items before deploying AI marketing at enterprise scale.

DOMAIN A · 10 ITEMS

Approval Workflow Controls

- ✓ **A1 (Critical)** — No AI-generated content can reach any distribution channel without at least one human approval recorded in a governed system.
- ✓ **A2 (Critical)** — Approval workflow routes content by channel, risk level, spend threshold, category, and jurisdiction — not a single generic review queue.
- ✓ **A3** — Approval SLA timers are configured with escalation paths triggered automatically when deadlines approach.
- ✓ **A4** — Approval decisions capture approver identity, timestamp, decision rationale, and linked content reference — not just a status update.
- ✓ **A5 (Critical)** — Policy override approvals require documented authority basis, justification, and risk acceptance — creating an auditable override record.
- ✓ **A6** — Multi-stage approval is available for high-risk content: regulated claims, senior-spend campaigns, and legal-sensitive materials.
- ✓ **A7** — Rejection decisions capture the rejection reason, reviewer identity, and return path — enabling structured revision without losing context.
- ✓ **A8** — Approval workload is visible across the team — preventing bottlenecks accumulating at a single reviewer without visibility.
- ✓ **A9** — External client or agency approval can be captured within the governed workflow — eliminating email-chain approval records.
- ✓ **A10** — Approval workflow configuration is version-controlled — enabling rollback and audit of workflow rule changes.

DOMAIN B · 9 ITEMS

Audit Architecture & Evidence Capture

- ✓ **B1 (Critical)** — Every material AI action creates an event record in the Audit Trail with actor reference, timestamp, and linked evidence ID.
- ✓ **B2 (Critical)** — Audit Trail records are immutable — no user, including administrators, can delete or modify logged events.
- ✓ **B3** — Decision Ledger captures the rationale behind approvals, rejections, overrides, and policy exceptions — not just the decision outcome.
- ✓ **B4 (Critical)** — Evidence Vault seals complete campaign evidence packages: prompts, AI outputs, policy check results, approvals, publish confirmations.
- ✓ **B5** — Evidence packages are exportable in formats suitable for legal review, regulatory inquiry, and procurement audit.
- ✓ **B6** — Forensic Hub enables cross-referenced reconstruction of any disputed event from linked audit, identity, and evidence records.
- ✓ **B7 (Critical)** — Identity Ledger binds every privileged action to actor identity, role, authority level, and session context.
- ✓ **B8** — Retention periods are configurable per record type, jurisdiction, and contract — with legal hold functionality.
- ✓ **B9** — Evidence retrieval achievable in under 30 seconds from the executive command layer without requiring engineering access.

DOMAIN C · 9 ITEMS

Brand Control & Compliance Policy Engine

- ✓ **C1 (Critical)** — Brand voice, tone, and vocabulary standards enforced at the AI content generation layer — not relied on through a style guide.
- ✓ **C2 (Critical)** — Pricing claims, performance assertions, and regulated terms detected and routed to compliance review before approval — not after publication.
- ✓ **C3** — Brand and compliance rules configurable per region, channel, language, product category, and jurisdiction.
- ✓ **C4** — Policy check results stored in the Evidence Vault — not just reported as pass/fail to the reviewer.
- ✓ **C5** — Channel-specific compliance rules applied at the activation stage — covering format, disclosure, and platform advertising standards.
- ✓ **C6** — Prohibited language, restricted claims, and required disclosures enforced at generation — reducing compliance violations reaching human review.
- ✓ **C7** — Policy rule sets are version-controlled — enabling rollback and audit of rule changes affecting content decisions.
- ✓ **C8** — Real-time policy violation alerts surface in the governance dashboard before content reaches market.
- ✓ **C9** — Jurisdiction-specific advertising regulations configurable per market without platform-level changes.

DOMAIN D · 8 ITEMS

AI Agent Authority Configuration

- ✓ **D1 (Critical)** — AI agent autonomy limits are configurable — defining the threshold at which agent actions require human review before execution.
- ✓ **D2 (Critical)** — No AI agent can publish content to any distribution channel without a completed, logged human approval — regardless of autonomy configuration.
- ✓ **D3** — AI agent tasks logged with model identity, prompt version, confidence level, risk score, and human handoff record.
- ✓ **D4** — AI-generated content is identifiable as AI-generated throughout the workflow — not presented as human-authored without disclosure.
- ✓ **D5** — Customer data is not used to train AI models — confirmed by contractual commitment and technical architecture.
- ✓ **D6** — AI agent configuration changes require approval and create audit events — preventing uncontrolled expansion of agent autonomy.
- ✓ **D7** — Risk scores are assigned to AI actions automatically and used to trigger appropriate escalation — not left to manual assessment.
- ✓ **D8** — AI governance posture aligns with NIST AI RMF: Govern, Map, Measure, and Manage functions demonstrably implemented.

DOMAIN E · 7 ITEMS

Access Control, Identity & Security

- ✓ **E1 (Critical)** — Role-based access control scopes permissions by workspace, brand, region, campaign type, and data sensitivity — not a flat permission model.
- ✓ **E2** — Enterprise SSO integration (SAML 2.0 / OIDC) available with SSO enforcement option for enterprise tenants.
- ✓ **E3** — SCIM 2.0 user provisioning and deprovisioning available for automated identity lifecycle management.
- ✓ **E4** — MFA enforced for all user accounts — supporting TOTP, FIDO2/WebAuthn, and hardware security keys.
- ✓ **E5** — All data at rest encrypted with AES-256. All data in transit protected with TLS 1.3 minimum.
- ✓ **E6** — Data Processing Agreement (DPA) available covering GDPR controller-processor obligations, SCCs, and subprocessor transparency.
- ✓ **E7** — Annual third-party penetration testing conducted with executive summary available to enterprise prospects under NDA.

Scoring guide & critical item summary

Critical items (A1, A2, A5, B1, B2, B4, B7, C1, C2, D1, D2, E1): 12 items representing governance failures with immediate legal, brand, or compliance consequences. All must be Implemented before enterprise AI marketing deployment at scale. Non-critical items: target 80%+ implemented before enabling full AI autonomous execution.

43

TOTAL ITEMS

12

CRITICAL ITEMS

5

GOVERNANCE DOMAINS

100%

TARGET: CRITICAL

For implementation support or a governance readiness review:

governance@zoikoververtex.com · security@zoikoververtex.com · zoikoververtex.com/trust